ONE-PAGE BRIEF

# Post-quantum cryptography review: foundry @ 7f0a409a5c20

Client: Foundry (Paradigm) — public repository (passive review) · Source: github.com/foundry-rs/foundry, commit `7f0a409a5c20` · Reviewed: 2026-11-04 20:31 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY

**Level 4 of 4**

post-quantum by default in the critical paths

FINDINGS

**0** Critical **4** High **7** Medium **5** Low **3** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 10 + 5 − 8 = 7 → **too late**

Signatures: 10 + 5 − 8 = 7 → **too late**

**Next step:** Keep the inventory current and review new code paths before release.

## WHAT MATTERS MOST

| | |
|---|---|
| High<br>QSI-2026-13370 | **Possible hard-coded secret in crates/evm/symbolic/src/runtime/solver/mod.rs** preliminary<br>What to do: Move secrets to a secrets manager/environment; rotate the exposed values. |
| High<br>QSI-2026-13372 | **Non-cryptographic generator next to key or seed generation in crates/anvil/src/cmd.rs** preliminary<br>What to do: Use the platform CSPRNG (secrets, os.urandom, crypto.getRandomValues, crypto/rand, SecureRandom, OsRng) or a hardware TRNG for every key... |
| High<br>QSI-2026-13378 | **quick-xml 0.39.4 is affected by RUSTSEC-2026-0194**<br>What to do: Upgrade to a fixed version (0.41.0). |
| High<br>QSI-2026-13379 | **quick-xml 0.39.4 is affected by RUSTSEC-2026-0195**<br>What to do: Upgrade to a fixed version (0.41.0). |

12 more in the full report.

## WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

| Role | Algorithms | What to do |
|---|---|---|
| Medium channel key exchange (TLS, Noise, handshakes) | TLS ECDHE | Move the handshake to a hybrid key exchange (X25519MLKEM768 in TLS 1.3; a hybrid KEM in Noise-based protocols) |
| Medium transaction and message signing | ECDSA, BLS12-381, Ed25519 | Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum... |
| Medium authentication and identity (certificates, tokens, device attestation) | ECDSA | Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them |
| Medium role not determined | BLS12-381, ECDSA | Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)... |

## KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 6; unlikely to apply to this build: 1 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 5.

Static review of source code and manifests; files analysed: 760. No requests were sent to the owner's systems.

Full report, content SHA-256: `ff7a682c497170f8daf477a628131ec90d11c35f06413bcbd468164adc567662`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.